

Security Awareness Program Proposal

A. Introduction

I. Purpose of Proposal

The most recent findings have determined that Multiple Unite Security Assurance Corporation or (MUSA) has had multiple security risk that can potentially expose the company to data breaches due to 10 security gaps that cause deficiencies within the companies' security. It is crucial that these security gaps are rectified to ensure the privacy, and safety of the data of the company and its users. The purpose of the security awareness program is recommended to ensure that all employees are on the same page with protecting the companies and its user's data. Failure to comply can put the company at risk for cyber-attacks as well as litigation.

Within the security awareness plan is the communication plan in describing how a security awareness plan is beneficial to the company, and its stakeholders, and explaining how a security incident will be handled also known as the incident response plan (Yasar, 2023). A security awareness plan relies heavily on the communication within all departments regarding security measures. A communication plan ensures that all parties involved know, understand the plan, are aware of the risks of security measures, and how to safeguard company and customer information.

A communication plan is a strategy that explains how communication within an organization should occur between external and internal stakeholders during a cyber security incident (Chapple, 2024). These incidents include external security breaches as well as internal breaches. Not only does a communication help ensure all members are on the same page with cyber security incidents, but it also ensure its members are able to properly handle other IT

emergencies such as system failure and down time. This communication plan will help mitigate those damages if such instances occur.

As mentioned, the incident response plan is a crucial component of a security awareness plan. The incident response plan explains the many steps that are required to ensure a cyber incident does not have devastating impacts to the company. An incident response plan or IRP is a set of procedures that describes the proper response, and detection of data breaches of a computer network(Somers, 2018). These steps consist of preparation, detection & analysis, containment eradication & recovery, and post incident activity. During the preparation phase the company takes proactive steps before an event occurs in creating an IRP, providing employees with training, and identifying potential threats that can occur within the network (Cassetto, 2023).

In the preparation phase of the IRP, it is important that everyone in the company knows their part in how to maintain the security and protection of the company. The identification phase of an IRP is the phase in which the organization determines if an incident occurred (Cassetto, 2023). During this time, analysts search for signs that determine a breach or incident is pending or has already occurred. The containment phase is a critical step in an IRP that involves the immediate action of an organization to contain the spread of the breach or incident. The main goal in this phase is to mitigate the further damage by isolating affecting systems, containing the threat once it's been identified (Jones, 2023). Eradication includes the removal of the threat and restoring the affected systems. This involves eliminating any malware that may have gained access to the system via manually or using tools such as antiviral tools to delete the malicious software (Somers, 2018).

After the eradication is the recovery of the system to rebuild into a better state it was in before the attack, that will prevent another attack from reoccurring. Key steps in this process are the repair of vulnerabilities as well as communicating with stakeholders to determine what is important and remain in constant communication on the progress and proper steps that were taking from users (Somers, 2018).

The investigation phase of the IRP involves the stage where the security team thoroughly analyzes the root cause of an incident (Jones, 2023). This involves how it occurred, and how it impacts the company. During the investigation, the team determines the method of attack, how it affected the systems including the damage it caused to the network or affected systems.

In the notification phase the proper departments are alerted. This includes contacting the incident response team, key stakeholders and the potential affected users (Jones, 2023). The key important factor in this phase includes the timely response to mitigate the severity of the damage. In addition to mitigating the damage the proper notification to the stakeholders is vital to maintain trust and manage expectations.

The purpose of these plans is to provide employees with the knowledge of how to protect the companies' assets, data, and financial resources. The program should be easy to be understood from all parties that have could contribute to the safety and security of the organization. This includes external and internal sources. The program includes both methods acknowledging the needs of the company for cyber security awareness and training. Awareness includes the process of educating and providing the employees the knowledge needed to understand the importance of cyber security safety. The more an employee is aware of the concerns the more liable they are to report any cyber security concerns when they occur promptly. Failure to report/or respond to

these threats could result in disciplinary action for noncompliance. As mentioned above, MUSA has security threats that contribute to the low security posture of the company. The security gaps that are present are as follows:

1. No annual cyber security awareness training

Cyber security awareness training is the process of making employees and stakeholders aware on how to identify and avoid cyber threats. The goal is to mitigate or prevent these threats in total. Cyber threats include threats that can happen internally as well as externally. The most prevalent attacks today are social engineering attacks. Currently the company does not provide annual cyber security awareness programs. This is causing high phishing and social engineering attacks. The first policy that would be implemented is a social media engineering policy. Social engineering attacks rely on then psychological manipulation of human behavior to. Disclose sensitive data, share credentials, grant access to a personal device, or company network (Lenearts, 2023).

The method in which cyber criminals use social engineering is to spread fear or a sense of urgency to gain this information. This could include an urgent payment, or email claiming exposure to an account requiring prompt response to update security information. The most common form of social engineering is phishing. With big companies such as MUSA, social engineering attacks such as phishing, whaling, tailgating/piggybacking are at high risk(Lenearts, 2023). Phishing is the practice of sending emails, or text messages posing as an authorized person to gain personal information such as passwords, credit card numbers, and other proprietary information (Gilis, 2024). Whaling is a type of phishing attack that involves attacking a specific person and usually a high- level executive in businesses (Lutkevich, 2021).

It is imperative that all employees even high levels of employees are aware of the dangers of phishing by this cyber security awareness program.

Tailgating or piggy backing is a physical breach in which an attacker gains entry to a physical facility by asking a person ahead of them to hold the door or grant them access (Lenearts, 2023). This can be a delivery driver, or an ex-employee impersonating as someone that is currently employed. Each employee must be aware of the protocols when entering or exiting the building or sharing company access and badges. Due to these security risks each employee is required participate in a quarterly awareness cyber security program. This will ensure each employee is aware of best practices to prevent social engineering attacks by phishing attempts. The training will provide employees answers and training to report suspicious activity to its appropriate channels, as well as how to respond to such phishing attacks.

Stimulation phishing test will be implemented to provide examples to employees on how phishing attempts occur and the proper procedures report such activity. Phishing attempts are the number one cause of cyber-attacks, and it continues to grow year after year (Lutkevich, 2021).

Click and Report phishing simulations can help provide insight on how successful a companies' security awareness program is improvement the security posture (Iler,2024). This will also provide where any changes occurred, and if any changes need to be made to the awareness program to ensure its effectiveness. Behavior metrics can help the security team identify gaps between the knowledge, and behaviors that influence certain risk factors (Iler,2024). This risk factors include unintentional errors such as an employee reusing the same password, not changing their passwords frequently enough or bypassing data loss prevention software (Iler,2024).

Human firewall can also help mitigate these gaps and security risks due to unintentional errors. Human firewall refers to individuals that are educated, and vigilant about cyber security threats (Mosher, 2024) They follow best practices to prevent the attacks and report breaches or suspicious activity expeditiously. According to hbs.net, 90% of cybercrime is a result of human behavior (Mosher, 2024). Companies should be equally focused on the human knowledge of cyber protection just as equally as they are focused on the technology and tools to mitigate this risk.

2. No configuration change management policy

A lack of a configuration change policy leaves more chances for unintentional errors. This is due to having to rely on manual processes in gathering data, and an absence of guidelines and procedures to identify on how to manage changes to system configurations (Pourkhomami, 2023). This deficiency can lead to significant vulnerabilities due to outdated or poor configuration settings. This can expose sensitive proprietary information to unauthorized users. Currently the company does not have a configuration change management policy. The need for a policy such as this will ensure all network configurations changes that occur are done and approved by the appropriate channels. Without a clearly directed policy, it is difficult to hold the appropriate personnel accountable when changes are made thus making it difficult to pinpoint the source of security issues. Additionally, many of the compliance regulations require a configuration change management practice (Pourkhomami, 2023). As a result, failure to have one established could cause a company to be noncompliant.

A good configuration change policy requires clear documentation on all the changes that are made to system configurations. The use of access controls such as Role Based, Attribute based, or Discretionary access controls will ensure that the data is properly secure (Jones, 2023).

This includes all details including the time, date, who made the change, and why the changes were made. This will ensure that any changes that are made to the companies' infrastructure such as hardware and software changes, require approval. Some elements of this policy include requirement of approval as mentioned above, baseline configurations, change control, audit logs, and disciplinary action if the policies are not implemented up to company standards (Pourkhomami, 2023)

As mentioned above it is imperative that all changes go through the appropriate channels to get reviewed and approval prior to the changes that are made. This will ensure that no unauthorized personnel are able to go into the network to change any configurations. This will mitigate the risk of threats caused by misconfigurations and hold the person or persons accountable for any mishaps that may arise out of the misconfiguration. A change control policy is also important as it is used to ensure the integrity of assets. Change control includes tracking, reviewing, approving and denying changes (Pourkhomami, 2023)

Properly vetting change requests are best practices that would be implemented in this policy. An automation tool will help this process by taking care of repetitive tasks like logging changings, tracking configurations, and creating documentation. It can also create reports and audit trails for compliance reports ensuring that the company is upholding regulatory standards. It is imperative to consider the security impact that could occur if such changes occur and are not reviewed properly. Regularly auditing logs of changings before and after changes are made can

help keep track of the changes, and if the changes complied with the allowed permissions.

Failure to comply with the above actions can lead to disciplinary action.

3. No Intrusion detection/ prevention system or IDS/IPS

A continuous monitoring plan was developed to ensure the safety, and security of the company's network. A continuous monitoring plan is important to a company as it provides proactive identification of potential security threats and addresses these security threats promptly (Benson, 2024). The prompt rectification of security threats allows the mitigation of damage security threats pose to the company's network. Through vulnerability scans, and proper firewall and antivirus protection, we can ensure the company information is secure to prevent data breaches, and financial losses, and litigation. This will also ensure the company properly maintains compliance and regulatory standards. Therefore, it is required that the company has a proper IDS/IPS system to detect these threats, eliminate them or mitigate the damage that they can cause if left unnoticed.

The lack of an IDS allows for external or internal cyber-attacks as there is not a method of monitoring traffic. An intrusion detection system is required to prevent network threats and take steps to stop threats when they are detected. An intrusion detection system policy or (IDS) is a guide that assists in how an organization monitors and responds to suspicious active or cyber-attacks on its network and or information systems (Ashoor, Gore, 2011). This is a vital policy in an organizations' cyber security strategy. It helps maintain the integrity and security of information systems. Failure to have an IDS can cause the exposure of customers or users' data that is stored on the system due to data leaks (Ashoor, Gore, 2011). In the intrusion detection

policy, an intrusion detection/ prevention system is required to be able to monitor and prevent this from occurring (Ashoor, Gore, 2011).

Best practices that will be implemented in this policy include intrusion detection parameters. This helps define the way that the IDS recognizes potential threats. Intrusion event logging would be required to log intrusions to have a proper documentation trail (Ashoor, Gore, 2011).

A network analysis policy would be developed to delegate how traffic is coded and to compare the incoming traffic to the new traffic to determine whether there is an intrusion attempt (Ashoor, Gore, 2011). Rules in firewall programs will be set to use as a filter to compare the incoming packet data to the current data to determine if there's an attack as well. Lastly, it is imperative that the proper channels must be notified in the event an intrusion does occur. This will ensure the prompt rectifying of the issue in the event of an attack which will minimize the exposure risk.

To provide prompt identification, the company will use methods of intrusion detection systems that can help detect vulnerabilities in a network. The company will use both unauthenticated and authenticated vulnerability scans. Authenticated vulnerability scans involve scanning the data using valid credentials (Ali, 2023). This is typically done through administrators. The approved authenticated scanner that would be used would be OpenVAS. OpenVas will allow administrators to do assessments of the security posture of a system. It can also examine user specific access controls, and permissions to determine if who is accessing certain systems are authorized to access those systems (Team, 2023)

OpenVas will also help find dangers within the system that will help set proper security protocol as it relates to ensuring employees are updating, and or using strong passwords, installed apps are approved by the company, and employees are not connecting personal devices to company computers that may allow the corruption of the network by downloading of malware. OpenVas is also able to find configuration issues within the system. Authenticated scanning is useful when assessing the security of internal systems such as servers, databases, and workstations within the network (Ali, 2023). This allows for a more comprehensive assessment of potential vulnerabilities specifically related to user accounts and configurations.

Unauthenticated vulnerability scanning is the scanning of the network without network permissions (Ali, 2023). Unauthenticated vulnerability scans help determine vulnerabilities from a cyber criminal's point of view. The approved unauthorized vulnerability scanner that would be used is Nmap/Network Mapper. Nmap involves the scanning of internet facing systems such as websites and network infrastructure that is accessible to the public (Yen, 2024). These vulnerabilities are due to open ports, outdated software, and server misconfigurations (Yen, 2024). The benefit of using this unauthenticated vulnerability scanner is the early detection of vulnerabilities that will mitigate the risk of cyber-attacks which can cause the company fines, and litigation as well as damage to the company's reputation.

In addition to utilizing vulnerability scanners or Intrusion Detection Software (IDS), intrusion prevention software (IPS) will be utilized. An approved IDS/IPS system is SNORT. Snort is an approved open-source IDS that will be used to detect intrusions. It is both an IDS, and IPS solution that provides detection, prevention, network analysis and packet recording in real time (Yadav, 2024). Multiple attacks can be found using snort such as denial of service (DoS),

distributed DoS (DDoS), and Common Gateway interface attacks (CGI) (Yadav, 2024). Snort detects intrusions using a rule-based system to analyze traffic and identify patterns that may indicate a cyber-attack. These patterns include port scans, exploit attempts or also known attack signatures within the network packets. Alerts are generated when it finds a match within those rules. From those set of rules an application is either whitelisted or allowed on the network or blacklisted and prevented from accessing the network (Yadav, 2024).

A IPS examines network traffic and identify potential threats by detecting anomalies in the network to determine if there is malicious activity (Gillis, 2023). SNORT used in conjunction with an Nmap, will help protect the company's network. IPS software also includes software like antivirus, and firewall. Firewall will block and filter unwanted traffic. Using Snort, all incoming traffic will pass through filters that involve a set rules to determine if they are allowed to pass (Darrington, 2024). If the Snort detects suspicious traffic, it will block, and drop the connections and alert the proper channels (Darrington, 2024). Lastly, the company will use data encryption methods to ensure all data that is transferred to and from its owner.

This ensures that only the intended party can read the data and prevents cyber criminals from accessing sensitive data. There are different types of encryptions. and each has its own benefit based on the needs of the business. Two types of encryptions that will be used is cloud encryption and AES encryption. Cloud encryption will protect data that is transferred via cloud service (Cocoara, 2024). AES or advanced encryption standard is widely used in the industry and was developed by the National Institute of Standards and Technology (NIST). It is used for protecting data in databases, and hard drives (Cocoara, 2024). AES is the strongest encryption standard that is readily available today (Jena, 2024).

4. Logs are not being collected or analyzed

This results in a slow, and ineffective incident response system allowing more damage to the company's systems. When logs are not collected and analyzed, it also allows for cyber criminals to access additional systems, extract and destroy more data. Log collection includes parsing, converting, and filtering logs. Log monitoring includes alerting for any anomalies in the traffic that is collected and reporting the anomalies to the appropriate channels. Log monitoring also allows the company to see who accessed the information, and what information was accessed as well. Not only is it to regular monitor logs for external threats, but it is imperative to monitor logs for internal threats as well. Internal threats can be caused by disgruntle employees due to the low morale that is an issue currently at MUSA.

With log monitoring, it is possible to see if an employee is accessing the network repeatedly when traveling in different countries due to multiple IP addresses. This can indicate things such as insider trading. It is important to regularly view, and audit the companies logs to be able to identify potential threats and address them promptly. After the logs are reviewed, if any suspicious activity is found, it is imperative that the suspicious activity is brought to the appropriate channels to mitigate risk. In addition, auditing the network for the vulnerabilities more often, will assist the company in finding risks, and repairing those vulnerabilities to mitigate cyber-attacks.

5. No media access control policy

Without a media access control policy, the company faces risks for data breaches, monetary losses, noncompliance with regulatory requirements, operational disruptions, insider threats, and damages to the company reputation (Pacheco, 2023). Media access control or MAC

is a network data transfer policy to determine how data is transmitted between devices on the network (Mehl,2021). This helps to prevent unauthorized access and improve network security. In the MAC policy, rules are set to prevent data collisions, improve network security, and ensure that proper bandwidth is always available to prevent clogging of the network so that it runs smoothly and effectively (Mehl,2021). To prevent data collisions, a MAC policy ensures that only one device can communicate at a time. Doing this will also resolve the bandwidth concern and ensure proper bandwidth is always available. Improvement of network security is done by the filtering of MAC addresses to prevent unauthorized access (Mehl,2021). To ensure that data is transmitted safely employees must also not attach personal devices into company computers. Employees will be required to download an authenticator apps to provide passcodes or tokens before the permission of transmission of data is granted (Mehl,2021).

6. No encryption or hashing to control data flow, and unauthorized alteration of data

No encryption or hashing methods can cause serious damage to the company as sensitive or proprietary information is not kept secure, which can cause a violation in data breach laws. This can cause legal ramifications for the company. As mentioned above the company will use AES and cloud encryption to ensure that data that is being transmitted to and from the company is always secure and unable to be read by unauthorized personnel.

7. Vulnerability assessments are conducted every three years

If the company systems are not routinely checked more frequently, this can increase the risk of unauthorized data access. A network audit policy will determine the rules in which MUSA network security is managed. Scans/ audits are performed to determine if employees are not abiding by these policies, and how to handle the violations if they are not. Vulnerability

assessments also provide insight to security risks and how to rectify the risk before they are exploited by a cyber attacker. (Tripathy, 2024).

8. High Turnover and low morale among the employers:

When experienced staff leave the company, it causes a loss in institutional memory and can leave the company open to cyber security attacks. In addition, training should be readily available to all employees, and development opportunities should be awarded as well. Employees will be recognized for hitting targets in cyber security awareness training, and recognition will be awarded in the method of merit increases. The higher an employee is training in cyber security awareness and best practices the greater the reward. Monthly goals and expectations should be discussed with all employees while setting realistic timelines to complete those goals.

A lack of morale can occur due to employees feeling ill prepared with a lack of direction on their role in the company and a path for their future within the company. This issue will also be rectified by developing onboarding programs that give new employees ample time to get adjusted, and knowledgeable on company procedures. Quarterly employee feedback will be provided to improve the training program, and to ensure its effectiveness.

9. High number of theft reports and security incidents

MUSA has also experienced a high number of theft reports or data breaches. A data breach is an event where data is stolen, accessed, changed, or copied by unauthorized personnel (Pacheco, 2023). Data breaches can occur by internal as well as external threats. Depending on the security incidents, or the data that was stolen this can cause financial loss, reputational damage, and legal ramifications. An incident response policy will help provide structure in identifying, containing

and mitigating incidents in an effective manner. The most common cause of data breaches according to tier point, comes from compromised or stolen credentials (Pacheco, 2023). The second most common form of data breaches occur from phishing, cloud misconfigurations, and third-party software (Pacheco, 2023).

Data breaches that involve specific kind of data are more common. These kinds of data that are more attractive to cyber criminals are Personal Identifiable Information (discussed later in the proposal) financial and health information, Intellectual property, competitive intelligence, legal information, and IT security information (Barnet, 2024). Financial information is commonly used to commit fraud or identify theft to make unauthorized purchased in someone else's name. Health information commonly stolen to steal an individual identity and to commit health insurance fraud. Intellectual property is valuable for information such as trade secrets or any information that may be valuable to the buyer similarly to stolen health information, and competitive intelligence. Legal information or legal documents are valuable to cyber criminals due to the information that they may contain to commit fraud acts similarly to financial and health information. Lastly IT security information can be valuable to a cybercriminal as it can be used as backdoor to gain access to the system sometimes allowing access to entire systems (Barnet, 2024).

10. No segregation duties/ vacation policies

A lack of a SoD policy along with no mandatory vacation policy can cause the feeling of work overload in employees leading to unintentional error. Currently, there is not a clear indication of who oversees what task at MUSA which can cause a disruption in the safety of the network. This is caused due to the appropriate tasks and that they are not delegated to the

specialist who is hired for them. Documentation of individuals duties should be clearly explained so that the individuals are where they need to be to allow the systems to run smoothly.

The purpose of the SoD is to ensure that the same person is not in charge of initiating, approving, and reviewing the same action (Bowman, 2024). Examples of some role delegations are as follows: HR would oversee the hiring process and ensuring the proper roles, are fully staffed and the potential candidates are fully equipped to handle the tasks that is given. This will be done by extensive background checks, and carefully screening resumes. Payroll will oversee that staff are paid correctly, and in a timely fashion. In addition, it is will also be the employees' responsibility to approve timecards every week to minimize the payroll errors to ensure that each employee is paid on time. Failure to report time by the end of the week will lead to coaching and in the case of repeated offenses, could lead to a disciplinary path up to termination.

II. Security Posture

The immediate issues that need to be addressed are the lack of cyber security training which as a result puts the company at high risk of phishing and social engineering attacks. Lack of cyber security training can result in an employee releasing proprietary information to unauthorized personnel by not recognizing the signs of phishing. Untrained staff can also cause security breaches by clicking on a link from an external source in an email. There's also no intrusion detection. Intrusion detection is crucial in determining if there's a cyber-attack and whether the attack is coming from internal or external factors.

As a result of no intrusion systems, the logs are not being collected or analyzed to monitor patterns or spikes to detect unusual activity. In addition to the following concerns, media access is not monitored to determine if employees are accessing inappropriate sites that may

expose the network to attacks that can be detrimental to the company. An example, an employee was to enter a site that is not approved, this could download malware that can corrupt the network and cause a breach by showing a weakness to the system.

III. Human Factors

As mentioned above, human factors play a pivotal role in assuring the privacy and protection of the organization. Ensuring employees are properly aware of cyber security awareness protocols can help mitigate security risks. These risks that can occur if employees are not well trained include falling for phishing attempts, and insider threats whether intentional or unintentional. Intentional threats occur when an individual purposely harms the organization. These are seen by intrusion detection software that can detect if the breach occurs from within the organization. Unintentional insider threats result from negligent employees, or employee error. Such as stolen credentials or opening malicious emails that contain phishing attempts. Other human factors include third party, collusive, and malicious threats (Ahmed, 2020).

IV. Organizational Factors

Organizational factors for unhealthy security culture include many factors. One of the factors for an unhealthy security culture is lack of management prioritization (Iller, 2024). Employees should see their leader value security. Failure of leaders to lead by example can cause bad influences and employees to follow suit. Another organizational factor that can cause an unhealthy security culture is high staff turnover (Samosuick, 2023). High staff turnover changes the culture and makes it harder for all staff to be trained to ensure the safety and privacy within the organization (Samosuick, 2023). Lastly, poor communication detrimental to security culture

as risks often under these circumstances go unaddressed (Hofmann,2024). Failure to report risk can cause a delay in data breach that can result in more data loss.

B. Proposal

I. Human Factors

To mitigate human factors and how it impacts an organizations security posture, the need for this security policy was created. By focusing on both unintentional and intentional errors due to cognitive and psychosocial factors one could create a plan that will ensure the safety and security of the company. Some psychosocial factors include phishing attempts, as well as insider threats. Cognitive threats include the manipulation of data such as hacking, or incorrect data analysis.

i. Unintentional Threats

Employee training crucial in the mitigation of unintentional threats. Unintentional threats include mistyping an employee email causing the sharing of business information to an unauthorized source, phishing attacks by opening external links, and emails. The requirement for employee training is essential to the success of the improvement of security posture as the absence of employee training can be detrimental to the safety of an organization. Events such as simulation phishing tests can bring employee awareness on how to recognize and act in an event of a phishing attack in unintentional threats.

In addition to human error, the protection of data flow is pertinent in securing data information. It is imperative to ensure all data is encrypted when transferring to and from the network to prevent unauthorized access. To secure the transfer of the data the use of encrypted

communication is required when transferring sensitive data. Establishing clear guidelines for sharing this data is required, and the proper labeling and documentation is also required to mitigate poor communication.

i. Intentional Threats

Intentional threats include things such as malware, ransomware, accessing unauthorized user data, and malicious codes. These actions that are intentionally taken to either steal the company information, or cause damage to the company system. Vulnerability scanning, and proper employee training can mitigate these threats. By having an IDS/IPS system, using vulnerability scanning, SoD, and configuration change policy this can mitigate the risks of intentional threats that can cause the company financial loss, legal fines, and reputational damage.

II. Organizational factors

To mitigate human factors and how it impacts an organizations security posture, the need for this security policy was created. By focusing on both unintentional and intentional errors due to cognitive and psychosocial factors one could create a plan that will ensure the safety and security of the company. Some psychosocial factors include phishing attempts, as well as insider threats. Cognitive threats include the manipulation of data such as hacking, or incorrect data analysis.

Employee training is vital in the recognition of events intentional or unintentional errors. These errors range from intentional errors such as cyber-attacks to unintentional error such as phishing attacks. The requirement for employee training is essential to the success of the improvement of security posture as the absence of employee training can be detrimental to the

safety of an organization. Events such as simulation phishing tests can bring employee awareness on how to recognize and act in an event of a phishing attack in unintentional threats.

i. Data flow

In addition to human error, the protection of data flow is pertinent in securing data information. It is imperative to ensure all data is encrypted when transferring to and from the network to prevent unauthorized access. To secure the transfer of the data the use of encrypted communication is required when transferring sensitive data. Establishing clear guidelines for sharing this data is required, and the proper labeling and documentation is also required to mitigate poor communication.

ii. Work Settings/Planning

Organizational distractions are not uncommon in the workplace. Organization distractions are a result of mismanagement and can cause a decrease in productivity. To prevent distractions, it is required that employees work in a distraction free environment. Planning with goals and tasks for the day, and how complete those tasks and goals will help mitigate these distractions. Employee programs such as workplace accommodations that will allow the discounts for therapy, and time off will decrease the stress in the workplace. Team building exercises will create a healthy competitive environment that will drive company business and assist in the focus of employees. Encouragement to work with peers will assist in the increase in knowledge of company policies, and procedures, and assist in team building.

iii. Employee Readiness Programs

Employee Readiness programs will help foster the growth of a healthy work environment and encourages the satisfaction of the employees of the company. In shorter terms, happy employees translate to less employee turnover, and a higher security posture. Employees will be required to attend quarterly training to ensure they are up to date on proper security protocol in an event of a cyber-attack, and how to mitigate the risks of a cyber-attack. This includes ensuring the use of stronger passwords, and prevention of unauthorized use of company computers such as downloading software, accessing non-work-related sites, or connecting personal devices to work on computers. They will also attend training on how to prevent unauthorized access caused by social engineering attempts such as phishing. In addition to training, employees will be provided incentives for better health such as health assessment incentives that will foster better health management.

These health assessment incentives include discounts on health coverage as well as discounts on accommodations such as work-place gyms and work-place accommodations to encourage improvement of the physical, and mental health of its employees. In addition to programs to foster a higher security posture, employees will be given adequate time off to help manage work life balance, and the ability to join company employee resource groups (ERG's). It is proven that the more employees are involved in company related events, the better they perform within the workplace, and the longer they stay with the company (Cloud, 2024).

III. Communication Plan

A communication plan explaining how a security awareness program is beneficial to the company, and its stakeholders. A communication plan ensures that all parties involved know,

understand the plan, are aware of the risks of security measures, and how to safeguard company and customer information. A communication plan is a strategy that explains how communication within an organization should occur between external and internal stakeholders during a cyber security incident (Chapple, 2024). These incidents include external security breaches as well as internal breaches. Not only does a communication help ensure all members are on the same page with cyber security incidents, but it also ensure its members are able to properly handle other IT emergencies such as system failure and down time. This communication plan will help mitigate those damages if such instances occur.

i. Messaging Strategies

To have a successful messaging strategy, we must determine the areas of high risks. To determine these areas, we must take into consideration the cost of the security breaches and how might these security breaches impact the company. To fully understand the impact, we must be aware of regulatory compliance, current breaches that are popular today, as well as breaches that may contain personal identifiable information (PII). To do that we must emphasize the importance of employee training, and delegating roles to ensure everyone is taking a hand in ensuring the privacy and protection of the company.

Employees are to have quarterly simulation training where things such as phishing attacks are attempted. These emails must be made to look like actual attacks and display a message in the event an employee fails the training. Multiple fails of the training could lead to disciplinary action to emphasize the importance of cyber security awareness. The actions in this communication plan will help ensure that all parties involved are on the same page on how to act in the case of a security breach to help maintain company protection.

ii. Cyber Laws

Knowing cyber laws can help in the mitigation of legalities involving the mishandling of customers information. Cyber laws help to ensure the organization is handling customers, and the company's information responsibility. Cyber laws like the Cybersecurity Information Sharing Act (CISA) encourages the sharing of cyber threat information between the private sector and the government (Brands, 2023). The Gramm-Leach-Bliley Act (GLBA) protects the collection of financial information (Brands, 2023). The California Consumer Privacy Act (CCPA) requires businesses to provide disclosures on how their information will be stored, and collected and requires the business to provide customers the option of opting out of the selling of their personal information (Brands, 2023).

Cyber laws help ensure that the company is within compliance of regulatory requirements will prevent legal issues involving data privacy as well as preventing the loss of trust that can damage a company's reputation. Knowing cyber laws such as GDPR, and CCPA will assist employees and stakeholders in the knowledge of the storage, collection, and sharing of personal data (Luna, 2024). This information needs to be emphasized in the communication plan to ensure employees, and company stakeholders are knowledgeable of the risks. Cyber laws require the rapid disclosure of security breaches to its affected parties, and listing of how all data is collected, and how that information is used in the company's terms of service. The importance of cyber laws will be explained thoroughly in the company required quarterly training.

In addition to training, it is a must that we have the top hardware and software to prevent a cyber-attack, and that we have the buy in of all stakeholders. The emphasis on the importance of having top of the line protection should be explained as we should not cut corners on the privacy

and protection of the company. In combination with software and hardware to assist in the protection of the company, regular audits must be done, as well as mock penetration tests to expose any security risks the company's network may have. This can be done via authenticate and authenticated scanning methods.

iii. Personal Identifiable Information

Personal Identifiable Information is information that can be used to trace a person's identity such as their name, ssn, D.O.B, address, phone number, and any other information that can be used to identify a specific individual (Gillis, 2024). PII can be divided into two categories, indirect, and direct identification (Gillis, 2024). Direct identification includes full names, DL, and passport numbers. Direct identification directly identifies a person while indirect information can potentially identify the person (Gillis, 2024). This information may include partial addresses, or D.O.B. In the age where everything is readily available on the internet about customers, including sharing of data from smartphones and computers, it is crucial that a company practices safe habits of safely securing this information. This not only includes storing of the information but also explaining in the terms of service how this information would be used. In the event of a security breach, promptly identifying those affected individuals, and notifying them of the information that was exposed is vital in mitigating legal repercussions.

Cost of security breaches

Knowing the cost of the security breaches should be explained in detail in the communication plan as it can affect a company's bottom line. In 2023, it took 204 days to identify and contain most data breaches (Barnett, 2024). This is 204 days that customers and company information was exposed that could cause irreparable damage. In the US data breaches averaged 9.44 million

to identify and remediate, which translates to 140-160 per record compromised (Barnett, 2024).

This cost can cause a company to bankrupt by failure to protect the company network and properly train its employees on the importance of cyber security awareness.

Advantages of awareness program

Awareness program not only saves the company from exorbitant legal fees, but it also protects the reputation of a company. In addition, an awareness program provides employees with direction in the event of a cyber-attack due to the training and clearly communicated policies and procedures (Shah,2024). This will increase the security posture of the company by ensuring that each department and staff knows their role in the protection and safeguarding company and customer information (Shah,2024). The awareness program helps employees, and its stakeholders know how to properly respond in a security crisis mitigating the risk of legalities, and security breaches (Harford, 2022). The awareness program needs to be easy to understand for both departments in IT, as well as your everyday employees so that everyone is equally equipped with the information.

References

Ali, N. (2023, November 21). Authenticated vs unauthenticated scans.

<https://beaglesecurity.com/blog/article/authenticated-vs-unauthenticated-scans.html#:~:text=Unauthenticated%20scans%20are%20generally%20less,the%20target%20system%20using%20credentials.>

Ahmed, Y. (2020, January 30). Nuclear security: From securing one nuclear facility to securing the nation. IAEA. <https://www.iaea.org/bulletin/nuclear-security-from-securing-one-nuclear-facility-to-securing-the>

[nation#:~:text=Human%20factors%20can%20also%20lead%20to%20a,security%20issues%20facing%20nuclear%20and%20other%20industries.](https://www.iaea.org/bulletin/nuclear-security-from-securing-one-nuclear-facility-to-securing-the-nation#:~:text=Human%20factors%20can%20also%20lead%20to%20a,security%20issues%20facing%20nuclear%20and%20other%20industries.)

Ashoor, A., & Gore, S. (2011, January 1). Importance of Intrusion Detection System (IDS).

Barnett, C. (2024, April 12). The cost of a data breach for your organization. The Cost of a Data Breach for Your Organization. <https://www.mindpointgroup.com/blog/the-costs-of-a-data-breach>

Benson, K. (2024, June 10). Continuous monitoring: What you need to know and how to start in 5 steps. Pathlock. <https://pathlock.com/learn/continuous-monitoring/>

Bowman, K. (2024, October 24). What is separation of duties (SOD)?. Pathlock. <https://pathlock.com/learn/separation-of-duties-in-your-organization/>

Brands, M. (2023a, February 15). *2024 cybersecurity laws and legislation*. ConnectWise. <https://www.connectwise.com/blog/cybersecurity/cybersecurity-laws-and-legislation>

- Cassetto, O. (2024, September 4). *Incident response plan 101: The 6 phases, templates, and examples*. Exabeam. <https://www.exabeam.com/blog/incident-response/incident-response-plan-101-the-6-phases-templates-and-examples/>
- Chapple, M. (2024, January 12). Incident response: How to create a communication plan (w/ template). Search Security. <https://www.techtarget.com/searchsecurity/tip/Incident-response-How-to-implement-a-communication-plan>
- Cloud, H. (2024, October 28). 20 employee engagement statistics you need to know. HR Software to Improve Employee Experience & Employee Engagement. https://www.hrcloud.com/blog/20-employee-engagement-statistics-you-need-to-know?hs_amp=true
- Cocoara, Z. (2024, January 23). Five key benefits of encryption for Data Security. Endpoint Protector Blog. <https://www.endpointprotector.com/blog/five-key-benefits-of-data-encryption-for-security/>
- Darrington, J. (2024, May 16). Monitoring Networks with Snort ids-IPS. Graylog. <https://graylog.org/post/monitoring-networks-with-snort-ids-ips/>
- Gillis, A. S. (2023, April 11). What is an intrusion prevention system (IPS)?. Search Security. <https://www.techtarget.com/searchsecurity/definition/intrusion-prevention>
- Gillis, A. S. (2024, February 29). What is phishing? how does it work, prevention, examples. Search Security. <https://www.techtarget.com/searchsecurity/definition/phishing>

Gillis, A. S., & Bernstein, C. (2024a, June 21). *What is pii (personally identifiable information)?*: Definition from TechTarget. Search Security.

<https://www.techtarget.com/searchsecurity/definition/personally-identifiable-information-Pii>

Harford, I. (2022, April 5). How effective is Security Awareness Training? not enough | techtarget. <https://www.techtarget.com/searchsecurity/feature/How-effective-is-security-awareness-training-Not-enough>

Hofmann, S. (2024, September 4). The Ultimate Guide to a strong security culture. CyberPilot. <https://www.cyberpilot.io/cyberpilot-blog/the-ultimate-guide-to-a-strong-security-culture#:~:text=strong%20security%20culture,-,Reasons%20your%20security%20culture%20may%20be%20lacking,difficult%20to%20establish%20and%20maintain.>

Iler, M. (2024, April 23). 6 steps for building a strong security culture in your organization. LMG Security. <https://www.lmgsecurity.com/6-steps-for-building-a-strong-security-culture-in-your-organization>

Pacheco, M. (2023, December 8). *Exploring the consequences of data breach: Risks & implications*. TierPoint, LLC. <https://www.tierpoint.com/blog/consequences-of-data-breach/>

Jena, B. K. (2024, July 16). *AES encryption: Secure Data with Advanced Encryption Standard*. Simplilearn.com. <https://www.simplilearn.com/tutorials/cryptography-tutorial/aes-encryption>

Jones, F. (2023, May 6). *8 key steps for incident response planning*. CyberExperts.com.

<https://cyberexperts.com/8-key-steps-for-incident-response-planning/>

Lenaerts, B. (2023, November 8). *10 types of social engineering attacks*. CrowdStrike.

<https://www.crowdstrike.com/en-us/cybersecurity-101/social-engineering/types-of-social-engineering-attacks/>

Luna, C. dela. (2024, September 21). *2024 Cybersecurity Laws & Regulations*. eSecurity Planet.

<https://www.esecurityplanet.com/compliance/2024-cybersecurity-laws-regulations/>

Lutkevich,(2021, January 26). What is a whaling attack (whaling phishing)?. Security.

<https://www.techtarget.com/searchsecurity/definition/whaling>

Mehl, B. (2021, February 24). *Media Access Control: What is it and Overview*. Kisi.

<https://www.getkisi.com/blog/media-access-control>

Mosher, R. (2024, October 23). *What is a human firewall and what does it look like?*. HBS.

<https://www.hbs.net/blog/what-is-a-human-firewall>

Pourkhomami, P. (2023, August 7). *Configuration and change management best practices for*

SMBS - managed IT Services & Technology Consulting. OSIbeyond.

<https://www.osibeyond.com/blog/configuration-change-management-best-practices-for-smbs/#:~:text=The%20Cybersecurity%20and%20Infrastructure%20Security,than%20causing%20havoc%20and%20disruption.>

Samosuick, D. (2023, November 9). *The human factor in cybersecurity: The Greatest*

Challenge. part I: Blog - future processing. Technology & Software Development Blog | Future

Processing. <https://www.future-processing.com/blog/the-human-factor-in-cybersecurity-the-greatest-challenge-part-i>

Shah, C. (2024, September 26). Transforming security awareness into a culture: A strategic approach. Cyber Security Tribe - Insight for Cyber Professionals.

<https://www.cybersecuritytribe.com/articles/transforming-security-awareness-into-a-culture-a-strategic-approach>

Somers, M. (2018, November 7). *8 steps to a stronger cybersecurity strategy*. MIT Sloan.

<https://mitsloan.mit.edu/ideas-made-to-matter/8-steps-to-a-stronger-cybersecurity-strategy>

Team, D. (2023, November 14). *Access control: Models and methods*. PAM Platform.

https://delinea.com/blog/access-control-models-methods?hs_amp=true

Tripathy, S. (2024, March 21). What is a network audit?. Enterprise Networking Planet.

<https://www.enterprisenetworkingplanet.com/data-center/network-audit/>

Yasar, K., & Pratt, M. K. (2023, October 12). *What is Security Awareness Training?: Definition from TechTarget*. Search Security.

<https://www.techtarget.com/searchsecurity/definition/security-awareness-training>

Yadav, A. (2024, February 4). *Snort*. Medium. <https://medium.com/@4ghora/snort-fd160add185f>

Yen, L. (2024a, February 29). Nmap vulnerability scan: How to easily run and assess risk.

Datamation. <https://www.datamation.com/security/how-to-easily-run-a-vulnerability-scan-using-nmap/>